

BÁO CÁO KIỂM THỬ API

Thông tin cá nhân & nhóm

- Họ tên: Nguyễn Bùi Vương Tiến
- MSSV: 22120370
- Nhóm 11.

Thông tin nhóm 11

- Thông tin thành viên:
 - Giang Đức Nhật - 22120252
 - Phan Thanh Tiến - 22120368
 - Nguyễn Bùi Vương Tiến - 22120370
 - Lý Trọng Tín - 22120371
- Bảng phân công nhóm:

Tính năng	Mô tả	Thành viên
HR Administration	Quản trị hệ thống, cấu trúc tổ chức, user	Giang Đức Nhật
Employee Self-Service (ESS)	Cổng thông tin nhân viên tự phục vụ	Giang Đức Nhật
Recruitment	Tuyển dụng, theo dõi ứng viên	Phan Thanh Tiến
Performance Management	Đánh giá KPI, đề nghị xem xét, lưu lịch sử performance review	Phan Thanh Tiến
Reporting & Analytics	Báo cáo tùy chỉnh, xuất dữ liệu	Nguyễn Bùi Vương Tiến
Time and Attendance	Chấm công, Timesheets	Nguyễn Bùi Vương Tiến
Employee Management (PIM)	Quản lý hồ sơ nhân viên, báo cáo	Lý Trọng Tín
Leave Management	Quản lý ngày nghỉ, quy tắc nghỉ phép	Lý Trọng Tín

1. GIỚI THIỆU

1.1 Mục đích

Báo cáo này trình bày kết quả kiểm thử API cho module Timesheets của hệ thống OrangeHRM. Mục đích kiểm thử nhằm:

- Xác minh các chức năng API hoạt động đúng theo yêu cầu
- Kiểm tra xử lý lỗi và validation dữ liệu đầu vào
- Đánh giá các khía cạnh bảo mật của API
- Đảm bảo API tuân thủ các chuẩn RESTful

1.2 Phạm vi kiểm thử

Module Timesheets API bao gồm các endpoint:

- `/time/timesheets` - Quản lý bảng chấm công
- `/time/employees/{id}/timesheets` - Chấm công theo nhân viên
- `/time/time-sheet-period` - Cấu hình chu kỳ chấm công
- `/time/customers` - Quản lý khách hàng (CRUD operations)
- `/time/projects` - Quản lý dự án (CRUD operations)

1.3 Phương pháp kiểm thử

- **Positive Testing (14 test cases):** Kiểm thử với dữ liệu hợp lệ
- **Negative Testing (14 test cases):** Kiểm thử với dữ liệu không hợp lệ
- **Security Testing (12 test cases):** Kiểm thử bảo mật (SQL Injection, XSS, Authentication, Authorization)

2. MÔI TRƯỜNG KIỂM THỬ

2.1 Cấu hình hệ thống

Thành phần	Chi tiết
Hệ điều hành	Linux 6.12.41
Python	3.12.11
Pytest	9.0.2
OrangeHRM	Docker container
Database	MySQL

2.2 Cấu hình API

```
BASE_URL = "http://localhost:8080"
API_BASE_PATH = "/web/index.php/api/v2"
REQUEST_TIMEOUT = 30 seconds
```

2.3 Phương thức xác thực

- Session Cookie Authentication
- Cookie name: `_orangehrm`
- Tất cả các request phải có session cookie hợp lệ

3. TỔNG KẾT KẾT QUẢ KIỂM THỬ

3.1 Tổng quan

Loại Test	Tổng số	Passed	Failed	Tỷ lệ Pass
Positive Tests	14	11	3	78.6%
Negative Tests	14	13	1	92.9%
Security Tests	12	11	1	91.7%
TỔNG CỘNG	40	35	5	87.5%

3.2 Thời gian thực thi

- Tổng thời gian: 1.42 giây
- Thời gian trung bình/test: ~35ms
- Thực thi: 17/01/2026 17:21:01

4. CHI TIẾT CÁC TEST CASE

4.1 POSITIVE TEST CASES (14 test cases)

TC ID	Tên Test Case	Mô tả	Endpoint	Method	Kết quả
TC-POS-001	List all timesheets	Lấy danh sách tất cả bảng chấm công	/time/timesheets	GET	PASS
TC-POS-002	List timesheets with limit	Lấy danh sách với giới hạn (limit=5)	/time/timesheets	GET	PASS
TC-POS-003	List timesheets with offset	Lấy danh sách với phân trang (limit+offset)	/time/timesheets	GET	PASS
TC-POS-004	Get employee timesheets	Lấy bảng chấm công của nhân viên cụ thể (ID=1)	/time/employees/1/timesheets	GET	PASS

TC ID	Tên Test Case	Mô tả	Endpoint	Method	Kết quả
TC-POS-005	Get timesheet period	Lấy cấu hình chu kỳ chấm công	/time/time-sheet-period	GET	FAIL (BUG-002)
TC-POS-006	List customers	Lấy danh sách khách hàng	/time/customers	GET	PASS
TC-POS-007	List customers with pagination	Lấy danh sách khách hàng với phân trang	/time/customers	GET	PASS
TC-POS-008	Get customer by ID	Lấy thông tin khách hàng theo ID	/time/customers/1	GET	PASS
TC-POS-009	List projects	Lấy danh sách dự án	/time/projects	GET	FAIL (BUG-003)
TC-POS-010	List projects with pagination	Lấy danh sách dự án với phân trang	/time/projects	GET	PASS
TC-POS-011	Get project by ID	Lấy thông tin dự án theo ID	/time/projects/1	GET	FAIL (BUG-003)
TC-POS-012	Create customer	Tạo khách hàng mới với dữ liệu hợp lệ	/time/customers	POST	PASS
TC-POS-013	Create project	Tạo dự án mới với dữ liệu hợp lệ	/time/projects	POST	PASS
TC-POS-014	Update customer	Cập nhật thông tin khách hàng	/time/customers/1	PUT	PASS

Kết luận Positive Tests: Hầu hết các chức năng cơ bản của API hoạt động đúng (78.6% pass rate), nhưng có 3 lỗi được phát hiện:

- CRUD operations (Create, Read, Update) hoạt động tốt
- Pagination và filtering hoạt động đúng
- Nested resources (employee timesheets) hoạt động
- BUG-002: Configuration endpoint trả về startDay dưới dạng string thay vì integer
- BUG-003: Projects list endpoint thiếu customer relationship data (N+1 query problem)

4.2 NEGATIVE TEST CASES (14 test cases)

TC ID	Tên Test Case	Mô tả	Expected	Actual	Kết quả
TC-NEG-001	Get nonexistent employee timesheets	Lấy chấm công nhân viên không tồn tại (ID=99999)	404	422	FAIL (BUG-001)
TC-NEG-002	Get nonexistent customer	Lấy khách hàng không tồn tại (ID=99999)	404	404	PASS
TC-NEG-003	Get nonexistent project	Lấy dự án không tồn tại (ID=99999)	404	404	PASS
TC-NEG-004	Create customer missing name	Tạo khách hàng thiếu trường bắt buộc "name"	422	422	PASS
TC-NEG-005	Create customer empty name	Tạo khách hàng với name = ""	422	422	PASS
TC-NEG-006	Create customer name too long	Tạo khách hàng với name quá dài (100 chars)	422	422	PASS
TC-NEG-007	Create project missing customer	Tạo dự án thiếu customerId bắt buộc	422	422	PASS
TC-NEG-008	Create project invalid customer	Tạo dự án với customerId không tồn tại	422	422	PASS
TC-NEG-009	List with negative limit	Yêu cầu danh sách với limit âm (-5)	422	422	PASS
TC-NEG-010	List with negative offset	Yêu cầu danh sách với offset âm (-10)	422	422	PASS
TC-NEG-011	Invalid employee ID format	Yêu cầu với employee ID không hợp lệ ("invalid")	422	422	PASS
TC-NEG-012	Update nonexistent customer	Cập nhật khách hàng không tồn tại	404	404	PASS

TC ID	Tên Test Case	Mô tả	Expected	Actual	Kết quả
TC-NEG-013	Create project empty name	Tạo dự án với name rỗng	422	422	PASS
TC-NEG-014	Exceed max limit	Yêu cầu với limit quá lớn (10000)	422	200	FAIL (BUG-004)

Kết luận Negative Tests: API xử lý hầu hết các trường hợp lỗi tốt (92.9% pass rate), nhưng có 2 lỗi:

- Validate các trường bắt buộc (required fields) chặt chẽ
- Kiểm tra độ dài dữ liệu (max length) đúng
- Kiểm tra tính hợp lệ của tham số (negative values)
- BUG-001: Employee endpoints trả về 422 thay vì 404 (API inconsistency)
- BUG-004: Không validate limit quá lớn, chấp nhận limit=10000 (DoS vulnerability)

4.3 SECURITY TEST CASES (12 test cases)

TC ID	Tên Test Case	Mô tả	Kỹ thuật	Kết quả
TC-SEC-001	No auth list timesheets	Truy cập timesheets không có authentication	Authentication Bypass	PASS (401)
TC-SEC-002	No auth list customers	Truy cập customers không có authentication	Authentication Bypass	PASS (401)
TC-SEC-003	No auth create customer	Tạo customer không có authentication	Authentication Bypass	PASS (401)
TC-SEC-004	No auth list projects	Truy cập projects không có authentication	Authentication Bypass	PASS (401)
TC-SEC-005	SQL injection customer name	Tiêm SQL: <code>' ; DROP TABLE customers; --</code>	SQL Injection	PASS (Protected)
TC-SEC-006	XSS attack customer name	Tiêm XSS: <code><script>alert('XSS')</script></code>	Cross-Site Scripting	PASS (Sanitized)
TC-SEC-007	SQL injection project name	Tiêm SQL: <code>' OR '1'='1</code>	SQL Injection	PASS (Protected)

TC ID	Tên Test Case	Mô tả	Kỹ thuật	Kết quả
TC-SEC-008	Command injection	Tiêm command: <code>; ls -la</code>	OS Command Injection	PASS (Protected)
TC-SEC-009	HTTP verb tampering	Sử dụng PATCH method không được hỗ trợ	HTTP Verb Tampering	PASS (405)
TC-SEC-010	Oversized payload	Gửi payload 100,000 ký tự	DoS Attack	PASS (Handled)
TC-SEC-011	Path traversal	Tấn công: <code>../../../../admin/users</code>	Path Traversal	FAIL (BUG-005)
TC-SEC-012	DELETE method not allowed	Verify DELETE không được phép trên customers/projects	Authorization	PASS (405)

Kết luận Security Tests: API có bảo mật khá tốt (91.7% pass rate), nhưng phát hiện 1 **lỗi hổng nghiêm trọng**:

- **Authentication:** Tất cả endpoints yêu cầu authentication (401 khi không có cookie)
- **SQL Injection:** API được bảo vệ khỏi SQL injection attacks
- **XSS:** Dữ liệu được sanitize trước khi lưu
- **Command Injection:** Không thể thực thi system commands
- **Authorization:** DELETE operations không được phép, trả về 405
- **BUG-005 (CRITICAL):** Path traversal vulnerability cho phép normal user truy cập admin endpoints và lộ thông tin 188 users

5. PHÂN TÍCH VÀ ĐÁNH GIÁ

5.1 Điểm mạnh của API

5.1.1 Chức năng

- CRUD operations hoạt động đúng và đầy đủ
- Pagination và filtering được implement tốt
- Response structure nhất quán (data, meta, rels)
- Nested resources được hỗ trợ (employees/{id}/timesheets)

5.1.2 Xử lý lỗi

- Validation dữ liệu đầu vào chặt chẽ
- Mã lỗi HTTP phần lớn phù hợp, trừ employee endpoints (BUG-001)
- Error messages rõ ràng trong response body
- Kiểm tra trường bắt buộc (required fields)

- Kiểm tra độ dài và format dữ liệu
- Thiếu validation cho limit quá lớn (BUG-004)

5.1.3 Bảo mật

- Authentication bắt buộc cho tất cả endpoints
- Bảo vệ khỏi SQL Injection attacks
- Sanitize dữ liệu để phòng XSS
- Không thể thực thi OS commands
- HTTP verb validation (405 for unsupported methods)
- DELETE operation được restrict (405)
- **Path traversal vulnerability** (BUG-005 - CRITICAL): Cho phép unauthorized access vào admin endpoints

5.2 Kiến trúc API

RESTful Design

- Resource-based URLs
- Sử dụng HTTP methods phù hợp (GET, POST, PUT)
- Status codes phần lớn chuẩn, có inconsistency ở employee endpoints
- JSON request/response

Consistency

- Response format nhất quán
- Error status codes không hoàn toàn nhất quán (xem BUG-001)
- Naming conventions rõ ràng

5.3 Performance

- Thời gian response nhanh (~35ms trung bình)
- Pagination giúp giảm tải server
- Timeout được set hợp lý (30s)

6. KẾT LUẬN

6.1 Tổng kết

- **Tổng số test cases:** 40
- **Passed:** 35 (87.5%)
- **Failed:** 5 (12.5%)
- **Bugs phát hiện:** 5
 - **Critical:** 1 (Path Traversal)
 - **High:** 1 (Limit Validation)
 - **Medium:** 2 (API Inconsistency, Missing Customer Relationship)
 - **Low:** 1 (Data Type Issue)

6.2 Đánh giá chung

Điểm mạnh:

- Hầu hết chức năng cơ bản hoạt động đúng (87.5% pass rate)
- CRUD operations được implement đầy đủ
- Bảo vệ tốt khỏi SQL Injection và XSS attacks
- Authentication được enforce nghiêm ngặt
- Validation dữ liệu đầu vào chặt chẽ
- Performance tốt (~35ms average response time)

Điểm yếu nghiêm trọng:

- **CRITICAL:** Path traversal vulnerability (BUG-005) cho phép normal user truy cập admin endpoints
- **HIGH:** Không validate limit quá lớn (BUG-004), dẫn đến DoS vulnerability
- API inconsistency trong error handling (BUG-001)
- Performance issue do thiếu customer relationship trong projects list (BUG-003)